[LAW FIRM NAME]

IT INFRASTRUCTURE & CYBERSECURITY MEASURES

Technical Controls · Network Architecture · Endpoint Security · Cloud Governance

---

Document Reference: ITCS-001 | Version: 1.0 | Classification: Confidential — Internal
Frameworks: ISO 27001:2022 | NIST CSF 2.0 | CIS Controls v8 | Ghana Cybersecurity Act 2020 | COSO

CONFIDENTIAL — NOT FOR PUBLIC DISTRIBUTION

1. Document Control

Field	Details
Document Title	IT Infrastructure & Cybersecurity Measures
Document Reference	ITCS-001
Version	1.0
Status	Approved
Owner	Managing Partner / Designated IT Lead
Review Frequency	Annual or upon material change to IT environment
Applicable Frameworks	ISO 27001:2022 | NIST CSF 2.0 | CIS Controls v8 | Ghana Cybersecurity Act 2020 (Act 1038) | COSO ERM 2017

2. Purpose

This document provides a complete description of [Law Firm Name]'s information technology infrastructure and the cybersecurity measures in place to protect its systems, data, and operations. It is intended to demonstrate to clients, financial institution partners, and third-party reviewers the Firm's technical security posture and its alignment to internationally recognised cybersecurity standards.

The Firm operates a purposefully lean but rigorously secured IT environment appropriate to its size and the sensitivity of the data it processes as a professional legal practice.

3. IT Infrastructure Overview

3.1 Hardware Inventory

Asset Type	Description	Security Classification
All-in-One PCs	Desktop workstations used by fee earners and support staff; Windows OS	Firm-managed; endpoint protection installed
Personal Laptops	Authorised staff laptops for flexible working; subject to Bring Your Own Device (BYOD) policy	Firm security baseline required; MDM enrollment
Network Router	Primary internet gateway and traffic routing device	Secured; firmware updated; access restricted
Network Switch	Internal network switching for wired connections	Secured; VLAN configuration; physically restricted
Canon Multifunction	Combined printer, scanner, and fax unit	Access-controlled; print

Asset Type	Description	Security Classification
Device		queues cleared; network-isolated print function
USB / Removable Media	Restricted; requires prior IT Lead authorisation	Encrypted if used; usage logged

3.2 Software Environment

Software Component	Product / Version	Security Features Enabled
Operating System	Microsoft Windows (current supported version)	Automatic updates enabled; Windows Defender active; Windows Firewall enabled
Productivity Suite	Microsoft 365 (cloud-based)	MFA enforced; conditional access; data loss prevention; audit logging
Email	Microsoft Exchange Online (secured mail)	TLS encryption; spam filtering; malware scanning; phishing protection
Antivirus / Endpoint Protection	Licensed commercial antivirus (Windows-compatible)	Real-time protection; scheduled scans; auto-update enabled
Web Browser	Current supported browser(s)	Auto-update enabled; malicious site blocking
Website (Data Collection)	GDPR-compliant website with consent management	HTTPS; cookie consent; contact form data encrypted in transit

4. Network Architecture and Security

ISO 27001:2022 Annex A 8.20–8.22 | NIST CSF PR.IR | CIS Controls v8 — Controls 12–13

4.1 Network Design

The Firm's network is built around a single-site router and switch infrastructure. The network is segmented to provide appropriate separation between operational, guest, and device-specific traffic:

- Primary internal network: Staff workstations, Microsoft 365 access, printer access
- Guest/visitor Wi-Fi: Isolated from internal network; no access to firm systems or data
- Printer/MFD network segment: Canon device isolated from general data traffic where technically feasible

4.2 Network Security Controls

Control	Implementation	Standard Alignment
Firewall	Router-based firewall; Windows Firewall on all endpoints	ISO 27001 A.8.20; CIS Control 13
Wi-Fi Encryption	WPA3 preferred; WPA2 minimum on all wireless networks	ISO 27001 A.8.20; NIST CSF PR.IR
Network Access Control	Access restricted to authorised, registered devices	ISO 27001 A.5.15; CIS Control 1
Guest Network Isolation	Guest Wi-Fi segregated from internal network	ISO 27001 A.8.22; CIS Control 12
Remote Access	Encrypted VPN or Microsoft 365 secure access only	ISO 27001 A.5.14; NIST CSF PR.IR-01
DNS Filtering	Malicious domain filtering via ISP or dedicated DNS service	CIS Control 9; NIST CSF PR.PS

5. Endpoint Security

ISO 27001:2022 Annex A 8.7 | NIST CSF PR.PS | CIS Controls v8 — Controls 2, 10

Control	Implementation	Status
Antivirus / Anti-Malware	Licensed endpoint protection active on all firm devices; real-time scanning enabled	Implemented
Automatic Updates (OS)	Windows Update configured for automatic security patch installation	Implemented
Automatic Updates (AV)	Malware definitions updated automatically; verified monthly	Implemented
Windows Firewall	Enabled on all endpoints; outbound rules reviewed	Implemented
Disk Encryption	Full-disk encryption (BitLocker or equivalent) on laptops containing firm data	Implemented
Screen Lock	Auto-lock enabled after 5 minutes of inactivity on all devices	Implemented
USB Restriction	Removable media use restricted; requires IT Lead authorisation	Implemented
Software Restriction	Only authorised software permitted; admin rights restricted to IT Lead	Implemented

6. Microsoft 365 Cloud Security

ISO 27001:2022 Annex A 5.23 | NIST CSF PR.AA | CIS Controls v8 — Controls 3–5, 16

Microsoft 365 is the Firm's primary productivity and collaboration platform. The following security configurations are applied:

Identity and Access

- Multi-factor authentication (MFA) enforced for all user accounts
- Conditional access policies restrict access from unmanaged or high-risk devices and locations
- Privileged administrator accounts are separate from regular user accounts
- Global Administrator rights limited to maximum two designated accounts

Data Protection

- Data Loss Prevention (DLP) policies configured to detect and restrict sharing of sensitive data
- Information Rights Management (IRM) applied to confidential documents where appropriate
- OneDrive and SharePoint access governed by permission policies; external sharing restricted
- Microsoft 365 cloud backup or equivalent third-party backup service operational

Threat Protection

- Microsoft Defender for Office 365 (or equivalent) active for email threat protection
- Anti-phishing policies configured; safe links and safe attachments enabled
- Audit log retention enabled; admin activities and user sign-ins logged
- Security alerts configured for suspicious sign-in activity and policy violations

7. Email Security

ISO 27001:2022 Annex A 5.14 | NIST CSF PR.DS | CIS Control 9

The Firm operates a secured email environment through Microsoft Exchange Online with the following protective controls:

- Transport Layer Security (TLS) encryption for all email in transit
- DMARC, DKIM, and SPF records configured for the Firm's email domain to prevent spoofing and impersonation
- Spam and malware filtering with quarantine management
- Phishing awareness training provided to all staff annually
- Suspicious email reporting mechanism in place (staff instructed to forward to IT Lead)
- External email forwarding from firm mailboxes is disabled or restricted
- Confidential attachments transmitted externally are password-protected or encrypted where appropriate

8. Physical Security of IT Assets

ISO 27001:2022 Annex A 7.1–7.14 | NIST CSF PR.AA-05

- All firm IT equipment is located within access-controlled premises
- The network router and switch are housed in a secured location not accessible to unauthorised personnel or visitors
- Laptop devices are cable-locked or stored securely when not in use
- The Canon multifunction device is positioned to prevent overlooking of printed documents; print queues cleared after each use
- Equipment disposal follows a secure wiping procedure (NIST SP 800-88 or equivalent) before physical disposal
- Visitor access to office areas containing IT equipment is supervised

9. Data Backup and Recovery

ISO 27001:2022 Annex A 8.13 | NIST CSF PR.DS-11 | CIS Control 11

Backup Element	Configuration	Recovery Capability
Microsoft 365 Data (Email, OneDrive, SharePoint)	Microsoft built-in retention plus third-party backup service	Recovery to any point within 90-day retention window
Local Device Data	Staff required to save working files to OneDrive / SharePoint; local storage minimised	Recovered via cloud backup
Backup Frequency	Continuous / daily incremental for cloud data	Recovery Point Objective (RPO): 24 hours maximum
Backup Storage	Geographically separate cloud infrastructure (Microsoft data centres)	Offsite by design
Backup Testing	Restoration test conducted annually and documented	Recovery Time Objective (RTO): 24 hours for critical systems
Backup Integrity	Alerts configured for backup failure; IT Lead notified immediately	Verified via annual test

10. Cybersecurity Incident Detection and Response

ISO 27001:2022 Annex A 5.24–5.28 | NIST CSF DE, RS | Ghana Cybersecurity Act 2020

The Firm has implemented the following technical detection and response capabilities:

Detection

- Microsoft 365 Defender alerts and security notifications active
- Antivirus real-time detection with alert escalation to IT Lead
- Failed login monitoring through Microsoft 365 sign-in logs

- Staff trained to recognise and report suspicious activity

Response

- Documented Incident Response Plan (IRP) maintained as part of ISP-001
- Incident classification matrix distinguishes low, medium, high, and critical severity
- Critical incidents escalated to Managing Partner within 1 hour
- Personal data breach notification procedure integrated with IRP (72-hour DPC notification window)
- Post-incident root cause analysis and corrective action implemented and documented

11. Vulnerability and Patch Management

ISO 27001:2022 Annex A 8.8 | NIST CSF ID.RA | CIS Control 7

- Microsoft Windows and Microsoft 365 applications updated via automatic update mechanisms
- Critical security patches applied within 48 hours of release; non-critical within 30 days
- Antivirus definitions updated automatically with minimum daily frequency
- Third-party software (browsers, plugins) kept on current supported versions
- IT Lead conducts monthly verification that all devices are current on patches
- End-of-life or unsupported software is not permitted on firm devices

12. Third-Party and Vendor IT Security

ISO 27001:2022 Annex A 5.19–5.22 | NIST CSF GV.SC

Key third-party technology providers and their security assurance status:

Provider / Service	Data Processed	Security Assurance
Microsoft (Microsoft 365)	Email, documents, user data	ISO 27001 certified; SOC 2 Type II; GDPR compliant; DPA in place
Internet Service Provider	Network traffic (encrypted)	Service agreement with security obligations
Website Hosting Provider	Website content; contact form data	HTTPS/TLS; GDPR-compliant; DPA in place
IT Support Provider (if applicable)	Access to firm systems for support	Confidentiality agreement; access restricted to IT Lead supervision
Cloud Backup Provider (if applicable)	Backup copies of Microsoft 365 data	Encrypted storage; ISO 27001 or SOC 2 certified required

13. User Security Awareness

ISO 27001:2022 Annex A 6.3 | NIST CSF PR.AT | CIS Control 14

- All staff complete cybersecurity awareness training on joining the Firm
- Annual refresher training covering phishing, password security, device security, and incident reporting
- Specific training on Microsoft 365 security features and acceptable use
- Phishing simulation exercises conducted periodically
- Training completion recorded and reported to Managing Partner

14. Compliance with Ghana Cybersecurity Act 2020

Ghana Cybersecurity Act 2020 (Act 1038)

As an organisation operating digital information systems in Ghana, [Law Firm Name] acknowledges its obligations under the Ghana Cybersecurity Act 2020 (Act 1038), including:

- Implementing appropriate technical and organisational measures to protect its information systems
- Reporting significant cybersecurity incidents to the Cyber Security Authority (CSA) as required
- Cooperating with the CSA in the event of an investigation or national cybersecurity incident
- Maintaining documented cybersecurity policies and measures (fulfilled by this document and ISP-001)

15. Review and Approval

Field	Details
Document Owner	Managing Partner / Designated IT Lead
Approved By	Managing Partner
Date of Approval	_____
Next Review Date	_____ (12 months from approval or upon material IT change)
Version History	v1.0 — Initial issue

Framework Alignment Summary

This document is aligned to: ISO 27001:2022 (Annex A technical and physical controls); NIST Cybersecurity Framework 2.0 (Protect, Detect, Respond, Recover functions); CIS Controls v8 (Controls 1–18 as applicable to the Firm's environment); Ghana Cybersecurity Act 2020 (Act 1038) — organisational security obligations; COSO ERM 2017 — Risk Assessment and Control Activities components.